Relatório de Testes de Segurança & Defesa da API - Parte 2

Auditoria Prática de Resiliência: Validação de Dados, Mass Assignment e Headers HTTP

Vulnerabilidade 04: Falha na Validação de Tipos no DTO (Data Type Validation)

MÉDIA

Endpoint: POST /users

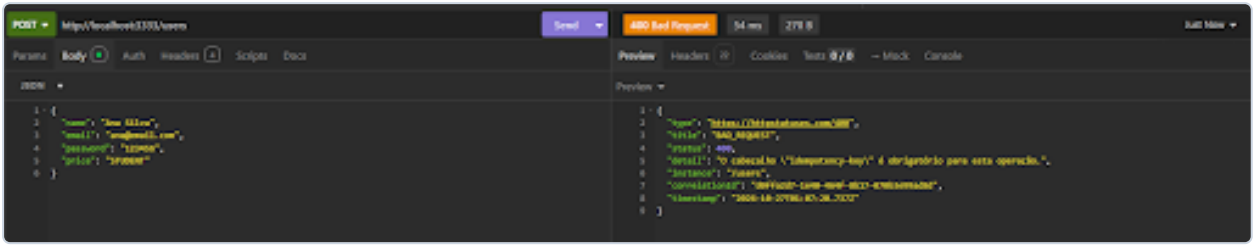
OWASP Category: API8:2023 Security Misconfiguration

CWE: CWE-20 (Improper Input Validation)

Código HTTP Retornado: 400 Bad Request

Descrição: Avaliou-se o comportamento do servidor ao receber campos com tipos incompatíveis com o schema esperado (ex: envio do atributo `price` contendo a string `"STUDENT"` em vez de um valor numérico).

Evidência Prática (Insomnia): O middleware intercepta a requisição e retorna o erro padronizado RFC 7807 indicando a falha de validação ou pré-requisito de cabeçalho:



Vulnerabilidade 05: Tentativa de Manipulação de Atributos Protegidos (Mass Assignment)

MÉDIA

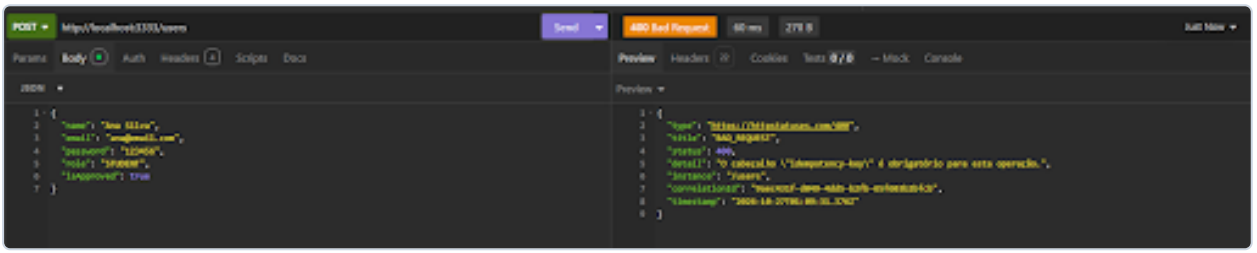
Endpoint: POST /users

OWASP Category: API3:2023 Broken Object Property Level Authorization

CWE: CWE-915 (Improper Control of Dynamically-Keyed Variables)

Código HTTP Retornado: 400 Bad Request / Sanitizado

Descrição: Foi enviada uma requisição contendo propriedades privilegiadas não permitidas no DTO do utilizador (`"role": "STUDENT"` e `"isApproved": true`) para verificar se a API permite elevação de privilégio não autorizada.



Vulnerabilidade 06: Auditoria de Cabeçalhos Defensivos HTTP e CORS

INFORMATIVA

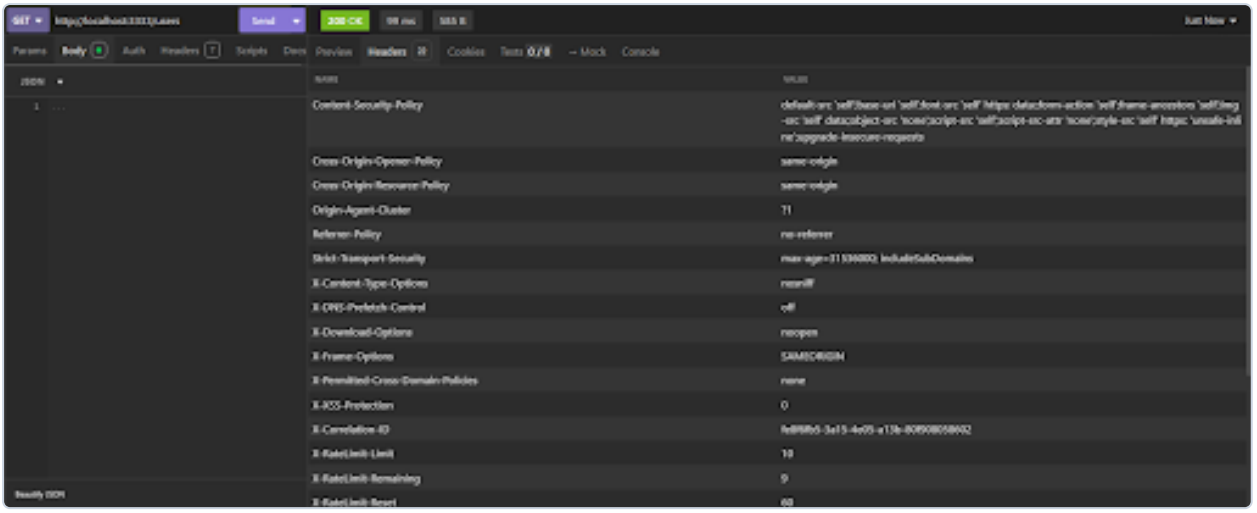
Endpoint: GET /users

OWASP Category: API8:2023 Security Misconfiguration

CWE: CWE-693 (Protection Mechanism Failure)

Código HTTP Retornado: 200 OK

Descrição: Inspeção dos cabeçalhos HTTP retornados pela API. Confirmou-se a presence de proteções essenciais contra Clickjacking (`X-Frame-Options: SAMEORIGIN`), MIME-sniffing (`X-Content-Type-Options: nosniff`) e diretivas rígidas de HSTS e CSP.



Vulnerabilidade 07: Tratamento Global de Erros Internos (Ocultação de Stack Trace)

BAIXA / DEFESA

Endpoint: GET /courses/teste

OWASP Category: API9:2023 Improper Inventory Management

CWE: CWE-209 (Sensitive Information Disclosure via Error Message)

Código HTTP Retornado: 500 Internal Server Error

Descrição: Provocou-se uma exceção não tratada ao buscar um recurso inexistente/inválido. A API respondeu com `500 Internal Server Error` em JSON padronizado, omitindo diretórios do SO ou informações do NestJS/Prisma.

